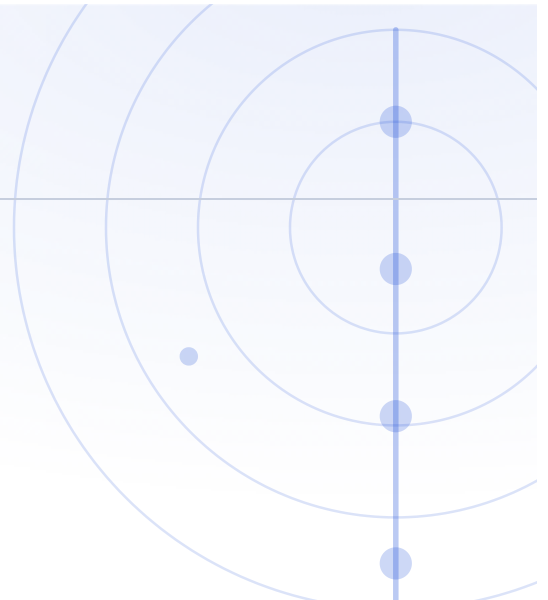


TLP: CLEAR

VULNERABILITY ANALYSIS **CVE-2021-34473** · +2

ProxyShell.

Three Exchange flaws that were patched four months before anyone attacked them, and were still open on 84,000 servers when the exploit went public.



SUBJECT TYPE Vulnerability · exploit chain	ATTRIBUTION No single actor · state and criminal	FIRST OBSERVED August 2021
ASSESSED RISK Critical	REPORT DATE 19 August 2026	IS ACTIVE? Yes

EXECUTIVE SUMMARY

ProxyShell is a sequence of three flaws in on-premises Microsoft Exchange Server that together turn an unauthenticated HTTPS request into code execution as SYSTEM on the mail server, with no credentials and no user interaction. Microsoft patched all three between April and May 2021. The attacks started in August, within a week of the full technique being presented publicly, and Rapid7 counted more than 84,000 servers still exposed at that point. What followed was not one campaign but many: Chinese espionage clusters, Conti and LockFile ransomware, and spam operators who used the access to reply to their victims' own email threads.

Patching by severity leaves this chain intact. Two of the three flaws score 9.8 and would be fixed on sight. The third scores 6.6 and requires administrator rights — rights the first two exist to supply. Anyone who drew a line under the criticals kept the route open.

Your exposure is one architectural question, not a sector. Every documented victim ran mail on an on-premises Exchange server. Exchange Online was never in scope. Hybrid deployments keeping a single on-premises box for attribute management are in scope and are the ones usually missing from the inventory.

This was never a zero-day, which makes it a patch-latency finding. Four months passed between the fixes and the first attacks. The first two CVEs were fixed before they were publicly documented, so an April cumulative update carried no visible urgency — and estates that react to published severity had nothing to react to until July.

The perimeter will not see it. The chain is unauthenticated HTTPS to port 443 on a server whose function is to accept unauthenticated HTTPS on port 443. Detection has to sit on what happens next: a web shell under the Exchange directories, a new mailbox granted remote PowerShell rights, an `ntdsutil` snapshot of the domain database.

Plan for minutes, not days. In the Conti intrusion Sophos documented, a web shell was running in under a minute and the network was mapped within thirty. A response plan that assumes a slow reconnaissance phase does not fit this entry vector.

Three flaws that only matter in order

ProxyShell is not a vulnerability but a route: three flaws in on-premises Microsoft Exchange Server that are individually survivable and jointly catastrophic. **CVE-2021-34473** is a server-side request forgery in the Autodiscover frontend that lets an unauthenticated request reach internal backends it should never touch. ¹ **CVE-2021-34523** is an elevation of privilege in the Exchange PowerShell backend, which trusts requests arriving down that frontend path. ² **CVE-2021-31207** is a security-feature bypass in mailbox export that writes a file of the attacker's choosing to a path of their choosing. ³ Run in sequence over port 443, they convert an unauthenticated HTTPS request into code execution as `NT AUTHORITY\SYSTEM` on an internet-facing mail server, with no credentials and no user interaction.

The middle link is what makes this a genuine attacker chain rather than three findings in one product. CVE-2021-31207 scores only **6.6 and requires high privileges**, which reads like a low priority until you notice that links one and two exist to supply exactly those privileges. ³ Each flaw is a precondition for the next, and each is close to useless alone: the SSRF is a reachability primitive with no code execution, the elevation has nothing externally reachable to elevate, and the file write needs administrator rights it cannot obtain by itself. This is the opposite of a remediation cascade, where the sequence describes versions a defender passed through — here *the sequence is the exploit*.

The exposure was created by publication rather than by discovery. Microsoft shipped fixes for the first two flaws on 13 April 2021 and for the third on 11 May 2021, without publicly documenting them at the time; the CVEs were assigned and described in July. Mass exploitation began on 12 August, within a week of the full technical detail being presented publicly, against an estate that had had four months to patch. Rapid7 estimated more than **84,000 Exchange servers** still vulnerable to the chain on 25 August 2021. ⁴ All three CVEs are listed in the CISA Known Exploited Vulnerabilities catalog. ¹¹

Exploitation, oldest first

2021-08

Eight distinct clusters exploit the chain across four sectors

Across August 2021 Mandiant Managed Defense responds to ProxyShell exploitation at organisations in education, government, business services and telecommunications across the US, Europe and the Middle East, and tracks eight separate UNC clusters using the chain. One of them, **UNC2980**, is assessed with low confidence to operate from China and to be conducting espionage; it is observed against a US university. Exploitation is largely automated and arrives from a wide range of source addresses and user agents. The web shells dropped include BLUEBEAM, a Java-based manager also known as Godzilla, and CHINACHOP, a minimal .NET injection shell. ⁵

2021-08-12

Mass opportunistic scanning and exploitation begins

Rapid7 detects widespread opportunistic scanning and exploitation of Exchange servers using the ProxyShell chain, a week after the technique was presented in full at Black Hat USA. By 21 August its managed detection and incident response teams record a significant increase in Exchange exploitation by multiple distinct threat actors. The chain requires no authentication and operates entirely over port 443, so it is not distinguishable from ordinary mail traffic at the perimeter. ⁴

2021-08-21

CISA issues an urgent alert with the estate still largely unpatched

CISA publishes an urgent alert on active exploitation of the three ProxyShell vulnerabilities. ⁹ Rapid7 estimates on 25 August that more than 84,000 Exchange servers remain vulnerable to the chain, more than three months after the last of the three patches shipped. ⁴

2021-08-27

LockFile chains ProxyShell to PetitPotam to take the domain

Sophos reports LockFile ransomware breaching unpatched on-premises Exchange servers through ProxyShell and then running a PetitPotam NTLM relay attack to seize the domain controller — a second chain bolted onto the first. The encryptor writes through memory-mapped I/O so the Windows System process performs the disk writes rather than the malicious process, and encrypts every other 16 bytes, which leaves files partially readable and keeps chi-squared statistics close to normal so detection built on entropy scoring does not fire. It uses no command and control, and deletes itself with a ping-based delay once finished. [7](#)

2021-09-03

Conti affiliates go from exploit to web shell in under a minute

Sophos documents a Conti affiliate intrusion beginning with ProxyShell against an Exchange Server 2016 running Cumulative Update 3. The operators create a mailbox named `administrator` and assign it Exchange roles including remote PowerShell rights, install a web shell in under a minute and a backup shell three minutes later, and finish mapping the network within thirty minutes. Credentials are harvested about four hours in, lateral movement over RDP follows roughly thirteen minutes after that, and around one terabyte is exfiltrated with rclone to Mega over two days. Conti is deployed on day five by four batch scripts targeting administrative shares by name. Seven separate persistence mechanisms are left behind: two web shells, Cobalt Strike, and four commercial remote access tools including AnyDesk, Atera, Splashtop and Remote Utilities. [6](#)

2021-11

SquirrelWaffle uses compromised servers to hijack real email threads

Trend Micro reports intrusions in which ProxyShell and ProxyLogon are used together against on-premises Exchange servers, with exploitation of CVE-2021-26855, CVE-2021-34473 and CVE-2021-34523 visible in the IIS logs of three compromised servers. Rather than encrypting or stealing, the operators use the access to reply to existing legitimate email threads with malicious spam that distributes the SquirrelWaffle loader. The messages come from the real correspondent's real server, which is what makes them work. [8](#)

HISTORY

Patched in April, dangerous in August

ProxyShell is unusual among Exchange chains in that it was never a zero-day. The whole exposure sits in the gap between a patch shipping and an estate applying it.

2021-04



Demonstrated at Pwn2Own, then quietly patched

The chain is demonstrated by researcher Orange Tsai at the Pwn2Own competition in April 2021. [9](#) Microsoft ships fixes for CVE-2021-34473 and CVE-2021-34523 on 13 April 2021 and for CVE-2021-31207 on 11 May, without documenting the first two publicly at the time; the CVE records are assigned and described in July. [4](#)

2021-08-05



Full technical detail is published, and the window opens

The chain is presented in detail in a Black Hat USA talk on 5 August 2021. [9](#) Scanning for vulnerable servers follows almost immediately [10](#) and mass exploitation begins on 12 August. Nothing about the vulnerabilities changed in those four months. What changed was that the exploit became reproducible by anyone, against a population that had treated an undocumented April cumulative update as optional.

The severity score hid the chain

ProxyShell is the clearest available argument against triaging vulnerabilities one row at a time. Two of the three flaws score 9.8 and would have been patched on severity alone; the third scores 6.6 with high privileges required, and reads on a spreadsheet like something to schedule for next quarter. It is also the link that turns the other two into remote code execution as SYSTEM. Anyone who patched by score and stopped at the criticals still had the chain. Once the technique was public, the same three requests were used for espionage, for ransomware with a five-day dwell time, and for sending spam that looked like it came from your own staff — because what the chain delivers is SYSTEM on a mail server, and what happens next is a matter of who arrived.

- 1 The 6.6 is the load-bearing link.** CVE-2021-31207 requires administrator rights it cannot obtain, which is exactly what the first two flaws supply. A triage process that sorts by CVSS and draws a line under the criticals leaves the chain intact.
- 2 This was never a zero-day.** Fixes shipped in April and May 2021 and exploitation started in August. Every compromised server had had four months, so the finding is about patch latency on Exchange, not about attacker capability.
- 3 Silent patching has a cost.** The first two CVEs were fixed before they were publicly documented, which meant an April cumulative update carried no visible urgency. Estates that patch on published severity had nothing to react to until July.
- 4 Detection at the perimeter will not help.** The chain is unauthenticated HTTPS to port 443 on a server whose job is to accept unauthenticated HTTPS on port 443. The observable is what happens afterwards — a web shell written under the Exchange directories, a new mailbox granted PowerShell rights, an `ntdsutil` snapshot.
- 5 Assume speed, not dwell.** The Conti intrusion had a web shell in under a minute and the network mapped in thirty. Response plans built around days of reconnaissance do not fit this entry vector.

One question decides your exposure

Sector matters less here than a single architectural fact: whether mail is still served from an on-premises Exchange box. The levels below follow the sectors where exploitation was actually reported.

Education and research		CRITICAL	Named first among the sectors Mandiant responded to, and the one documented espionage case — UNC2980, assessed with low confidence to China — was against a US university.
Government and public administration		CRITICAL	Named directly in Mandiant's account of the sectors exploited through this chain across the US, Europe and the Middle East.
Business and professional services		HIGH	Named in the same reporting, and the sector's characteristic mid-size on-premises Exchange estate is precisely the population that had not patched by August 2021.
Telecommunications		HIGH	Named in the same reporting. Nothing in the cited sources distinguishes it further, so this rests on observed targeting rather than on any specific incident.
Healthcare		MODERATE	Plausible and often heavily invested in on-premises Exchange, but no healthcare victim appears in any of the cited sources for this chain.
Retail and hospitality		LOW	No exploitation against retail appears in the cited reporting. The level reflects that absence rather than any protection — the ransomware crews using this chain selected by exposed server, not by industry.
Estates on Exchange Online only		MINIMAL	All three flaws are in on-premises Exchange Server. An organisation that moved its mail to Exchange Online was never in scope for this chain, which is the single clearest exposure boundary in this report.

 Critical — actively targeted  High — fits the victim profile  Moderate — plausible, not observed

 Low — outside the pattern  Minimal — no indication

Count your on-premises Exchange servers before you read the sector table. Every documented victim of this chain ran mail on a box they owned. Hybrid deployments retaining a single on-premises server for attribute management are in scope too, and are the ones most often missing from an inventory because nobody thinks of them as mail servers any more.

For *how* a compromise actually unfolds — the techniques, the tooling and the order they run in — see the companion attack-flow report.

What this analysis is built on

- 1 NVD — CVE-2021-34473 (Exchange SSRF, CVSS 9.8, CWE-918) — <https://nvd.nist.gov/vuln/detail/CVE-2021-34473>
- 2 NVD — CVE-2021-34523 (Exchange elevation of privilege, CVSS 9.8) — <https://nvd.nist.gov/vuln/detail/CVE-2021-34523>
- 3 NVD — CVE-2021-31207 (Exchange security feature bypass, CVSS 6.6, CWE-434, PR:H) — <https://nvd.nist.gov/vuln/detail/CVE-2021-31207>
- 4 Rapid7 — ProxyShell: more widespread exploitation of Microsoft Exchange servers — <https://www.rapid7.com/blog/post/2021/08/12/proxyshell-more-widespread-exploitation-of-microsoft-exchange-servers/>
- 5 Mandiant (Google Cloud) — PST, want a shell? ProxyShell exploiting Microsoft Exchange servers — <https://cloud.google.com/blog/topics/threat-intelligence/pst-want-shell-proxyshell-exploiting-microsoft-exchange-servers>
- 6 Sophos X-Ops — Conti affiliates use ProxyShell Exchange exploit in ransomware attacks — <https://www.sophos.com/en-us/blog/conti-affiliates-use-proxyshell-exchange-exploit-in-ransomware-attacks/>
- 7 Sophos X-Ops — LockFile ransomware's box of tricks: intermittent encryption and evasion — <https://www.sophos.com/en-us/blog/lockfile-ransomwares-box-of-tricks-intermittent-encryption-and-evasion/>
- 8 Trend Micro Research — Squirrelwaffle exploits ProxyShell and ProxyLogon to hijack email chains — https://www.trendmicro.com/en_us/research/21/k/Squirrelwaffle-Exploits-ProxyShell-and-ProxyLogon-to-Hijack-Email-Chains.html
- 9 CISA — Urgent: protect against active exploitation of ProxyShell vulnerabilities — <https://www.cisa.gov/uscert/ncas/current-activity/2021/08/21/urgent-protect-against-active-exploitation-proxyshell>
- 10 Tenable — ProxyShell: attackers actively scanning for vulnerable Microsoft Exchange servers — <https://www.tenable.com/blog/proxyshell-attackers-actively-scanning-for-vulnerable-microsoft-exchange-servers-cve-2021-34473>
- 11 CISA — Known Exploited Vulnerabilities Catalog — <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

Confidence and sourcing. CVE identifiers, scores, weaknesses and affected builds are reference data from NVD. The exploitation account rests on primary vendor and government reporting, and where a claim comes from a single vendor the report names it: the eight-cluster figure and the UNC2980 espionage case are Mandiant's, the two ransomware intrusions are Sophos's, and the email-thread hijacking is Trend Micro's. The UNC2980 attribution to China is reported as *low confidence* by Mandiant and is repeated at that strength here, not upgraded. **The *Is active?* cell reads Yes** on the basis of continued CISA KEV listing and the long life of unpatched on-premises Exchange; the most recent intrusion documented in these sources is from late 2021. Sector risk levels are analyst assessments, not measured values; they deliberately share a colour ramp with CVSS severity but are rendered as meters rather than scores so the two are not confused.

ATT&CK attack flow

How a compromise unfolds, tactic by tactic and in order. Part 1 established who is at risk and why; this part is how they get hit.

VULNERABILITY REPORT **MICROSOFT EXCHANGE SERVER · 2021**

ProxyShell.

Three Exchange vulnerabilities that are individually survivable and jointly catastrophic. Chained, they turn an unauthenticated HTTPS request into **arbitrary code execution as NT AUTHORITY\SYSTEM** on an internet-facing mail server — no credentials, no user interaction.

CHAIN

CVE-2021-34473

CVE-2021-34523

CVE-2021-31207

HIGHEST CVSS 9.8 Critical	PRODUCT Exchange Server	AFFECTED 2013 · 2016 · 2019
PATCHED Apr–May 2021	CISA KEY All three listed	AUTH REQUIRED None

A proxy trick, a forged identity, and a file write

These compose. Each CVE contributes one capability the next one needs and cannot obtain for itself. Read the *Alone* line under each — that is what separates a chain from three unrelated bugs sharing a nickname.

STEP	CVE	CVSS	EXPLOITATION	ROLE	WHY THIS POSITION
1	CVE-2021-34473	9.8	KEV	Pre-auth reach to backend	Nothing else in the chain is reachable from the internet without it.
2	CVE-2021-34523	9.8	KEV	Admin identity accepted	Converts reach into authority; useless without step 1 to deliver the request.
3	CVE-2021-31207	6.6	KEV	Arbitrary file write	The only step that leaves code on disk — and the lowest-scored of the three.



ATTACKER STARTS WITH

Network access to port 443. No credentials, no account, no foothold.

CVE-2021-34473

9.8 CRITICAL

KEV

CWE-918 SSRF

The way in. A path-confusion flaw in the Autodiscover frontend causes the Client Access Service to mis-parse an attacker-controlled URL and proxy the request to a backend endpoint of the attacker's choosing — pre-authentication, and carrying the frontend's own `SYSTEM` context.

Alone: a **reachability primitive, not code execution**. It lets an attacker knock on internal doors that should never face the internet, but every one of those doors still expects a privileged identity it has no way to present.



ATTACKER NOW HOLDS

Pre-auth reach into arbitrary Exchange backend endpoints

CVE-2021-34523

9.8 CRITICAL

KEV

CWE not assigned

The forged identity. An elevation-of-privilege flaw in the Exchange PowerShell backend: because the request arrives down the trusted frontend path, the backend accepts the caller-supplied access token at face value and services the session as an Exchange administrator.

Alone: an **elevation with nothing to elevate**. The vulnerable PowerShell backend is not exposed externally, so without link 1 there is no way to send it a request at all.



ATTACKER NOW HOLDS

Administrator session on Exchange Remote PowerShell

CVE-2021-31207

6.6 MEDIUM

KEV

CWE-434 Unrestricted Upload

The payload drop. A security-feature bypass in mailbox export. An administrator can write a mailbox export to an arbitrary path with an arbitrary extension, so a crafted mailbox saved as `.aspx` under a web-served Exchange directory becomes an attacker-controlled web shell.

Alone: **needs the Exchange administrator rights it cannot obtain.** That requirement is precisely why it scores 6.6 with high privileges required — an assumption links 1 and 2 have already demolished.



CHAIN OBJECTIVE REACHED

Unauthenticated remote code execution as NT AUTHORITY\SYSTEM

Why all three are needed. Remove any single link and the chain collapses. Without 34473 the vulnerable backend is unreachable. Without 34523 it is reachable but refuses to act. Without 31207 the attacker is an Exchange admin with no way to leave code on disk. None of the three is remote code execution; their composition is.

The scoring trap. The link that actually produces the shell is the one scored **6.6 MEDIUM** — because CVSS scores a vulnerability in isolation, and in isolation CVE-2021-31207 requires administrator rights. The chain hands those rights over for free. A triage process reading only base scores ranks the payload-delivery mechanism below dozens of unrelated highs. **Chains have to be assessed as chains.**

THE INTRUSION

From internet scan to encrypted estate

One flow, because a chain is one attack path. Phases 02–05 are the chain itself and each cites the CVE that enables it. Phases 06–08 are documented in-the-wild follow-on — what operators did *with* the access, not properties of the vulnerabilities, and they carry no CVE tag for that reason.

01



RECONNAISSANCE

Sweep the internet for unpatched Exchange

T1595.002

Active Scanning: Vulnerability Scanning — mass probing of internet-facing Exchange for the vulnerable Autodiscover endpoint. Exploitation began within days of the technique being presented publicly in August 2021.

↓ *a responding, unpatched frontend is the only prerequisite the chain has*

02



INITIAL ACCESS

Walk through the frontend proxy

T1190

Exploit Public-Facing Application — the Autodiscover path-confusion flaw proxies an unauthenticated request to a backend endpoint of the attacker's choosing. [via CVE-2021-34473](#)

↓ *reaching the backend is not the same as being allowed to use it*

03



PRIVILEGE ESCALATION

Be accepted as an Exchange administrator

Ordered before Execution deliberately: in this chain the elevation happens *during* exploitation, not after a foothold exists. There is no unprivileged stage to escalate from.

T1068

Exploitation for Privilege Escalation — the PowerShell backend trusts the access token attached to the proxied request and services it as an administrator. [via CVE-2021-34523](#)

↓ *an accepted admin identity unlocks the full Exchange cmdlet surface*

04



EXECUTION

Drive Exchange through Remote PowerShell

T1059.001 PowerShell — the attacker issues Exchange management cmdlets over Remote PowerShell, notably `New-MailboxExportRequest`, which is the vehicle for the next link. [via CVE-2021-34523](#)

↓ *a PowerShell session dies with the connection — the export writes something that does not*

05



PERSISTENCE

Leave a web shell on disk

T1505.003 Server Software Component: Web Shell — a mailbox export written as `.aspx` into a web-served Exchange directory becomes a durable, unauthenticated command channel running as SYSTEM. [via CVE-2021-31207](#)

↓ *the chain ends here — everything below is what operators chose to do next*

06



CREDENTIAL ACCESS

Harvest from a domain-joined server

T1003.001 OS Credential Dumping: LSASS Memory — SYSTEM on a domain-joined Exchange server is an unusually rich credential position, routinely used to pivot from the mail server into the wider domain.

↓ *on a mail server, though, the mailboxes are already the prize*

07



COLLECTION

Export the mail

T1114.002 Email Collection: Remote Email Collection — the same administrative export capability abused to plant the shell also exports mailboxes wholesale. Some operators used ProxyShell purely for this, hijacking live email threads rather than deploying malware.

↓ *for the ransomware crews, the mail server was only the front door*



IMPACT — OPERATOR-DEPENDENT

Whatever the operator came for

This phase is not a property of the chain. ProxyShell delivered access; what followed varied by who was holding it. Ransomware deployment was the most commonly reported outcome, but the same access was also used for pure email theft and for quiet long-term persistence with no destructive stage at all.

T1486

Data Encrypted for Impact — multiple ransomware operations used ProxyShell as an entry vector during late 2021, encrypting estates reached from the compromised Exchange server.



Tactic icon and label warm as exploitation advances



The spine tracks the same progression

T####

ATT&CK technique ID

via CVE

The CVE that enables this step

9.8

6.6

CVSS v3.1 base score

KEV

In CISA's Known Exploited Vulnerabilities catalog

One build number decides it

The two critical CVEs and the medium one were fixed in *different* updates. Patching to the April 2021 build closes the chain but leaves CVE-2021-31207 open to any account that already holds Exchange admin rights.

Patch to the May 2021 build or later

Only the later build closes all three. Verify the running build, not the CU label — a server on `15.02.0858.010` is patched for the two criticals and still vulnerable to 31207.

PATCH

Restrict the Autodiscover surface

Where patching is delayed, block untrusted external access to the Autodiscover endpoint and Exchange Remote PowerShell. A stopgap only — the chain needs nothing but reachability.

MITIGATION

Hunt the export, not just the shell

Look for `New-MailboxExportRequest` in Exchange admin audit logs, and for `.aspx` files under the frontend proxy directories. The cmdlet is the reliable signal; the shell filename is arbitrary.

HUNT

CVE	CVSS	CWE	ROLE IN CHAIN	FIXED IN (2019 CU9)
CVE-2021-34473	9.8	CWE-918	Pre-auth reach to backend	15.02.0858.010
CVE-2021-34523	9.8	Not assigned	Admin identity accepted	15.02.0858.010
CVE-2021-31207	6.6	CWE-434	Arbitrary file write	15.02.0858.012

What this mapping is built on

- 1 NVD — CVE-2021-34473 (pre-auth SSRF) — <https://nvd.nist.gov/vuln/detail/CVE-2021-34473>
- 2 NVD — CVE-2021-34523 (privilege elevation) — <https://nvd.nist.gov/vuln/detail/CVE-2021-34523>
- 3 NVD — CVE-2021-31207 (post-auth arbitrary file write) — <https://nvd.nist.gov/vuln/detail/CVE-2021-31207>

CVSS scores, CWE assignments, affected builds and KEV status verified against NVD.

Read the chain correctly. These CVEs genuinely compose — removing any one breaks the attack.

Derived mapping — read before citing. MITRE ATT&CK publishes no ProxyShell mapping, so the ATT&CK techniques on this page were **derived by analysis, not taken from a published source**. Every technique ID and tactic assignment was verified to exist against attack.mitre.org, but the decision to apply each one to this chain is an analytical judgment and should be reviewed before the page is used as an authority. The CVE facts in the chain and remediation sections are vendor and NVD data and are not derived.